

VAPT Project — Metasploitable 2

Full Vulnerability Assessment and Penetration Testing lifecycle conducted in a controlled virtual lab environment.

This repository is the evidence vault for my two-part VAPT series published on Medium. The target was **Metasploitable 2** — a deliberately vulnerable Linux machine designed for security practice.

If you landed here from the articles, this is where all the PoC screenshots live, organised by severity.

Medium Articles

Part	Topic	Link
Part 1	Vulnerability Assessment using Nessus	Read on Medium
Part 2	From Vulnerabilities to Exploitation — Completing the VAPT Lifecycle	Read on Medium

Lab Environment

	Details
Attacker Machine	Kali Linux
Target Machine	Metasploitable 2 — 192.168.4.33
Network Setup	Bridged Adapter (isolated lab)
VA Tool	Nessus Essentials
PT Tools	Custom Bash Script, Netcat, testssl, VNC Viewer, SSH Client

Findings Summary

Nessus identified **38 vulnerabilities** across all severity levels. Full scan results are in [Nessus-Scan-Results.xlsx](#).

Severity	Count
● Critical	7
● High	11
● Medium	14
● Low	6
Total	38

🎯 The Approach

Rather than relying entirely on automated exploitation frameworks, I focused on **manual and semi-manual PoC techniques** wherever possible. This demonstrates a deeper understanding of what's actually happening beneath the surface.

For the penetration testing phase, I focused on all **Critical** vulnerabilities first, then selected notable **High** severity findings worth demonstrating. The remaining Medium and Low findings are validated and evidenced in the PoC folders below.

● Critical Findings — Detailed in Part 2 Article

These are the vulnerabilities covered in depth in the Medium article, with explanation, validation method, result, and remediation.

1. Debian OpenSSH/OpenSSL Weak Keys — CVE-2008-0166 (CVSS 10.0)

Port: 22 | **PoC Folder:** `POC/Debian OpenSSHOpenSSL Package Random Number Generator Weakness/`

Debian's OpenSSL random number generator was broken — producing only ~32,767 unique SSH key combinations, all pre-computable. I wrote a **custom bash script** to iterate through the pre-generated key archive and find the matching key on the target.

Result: `uid=0(root) gid=0(root) groups=0(root)` — root shell confirmed with no password.

2. Bind Shell Backdoor Detection (CVSS 10.0)

Port: 1524 | **PoC Folder:** [POC/Bind shell POC/](#)

An unauthenticated shell listening on port 1524. Connecting with [nc 192.168.4.33 1524](#) immediately returned a root shell — no credentials, no exploit required.

3. VNC Server Default Password (CVSS 10.0)

Port: 5900 | **PoC Folder:** [POC/VNC POC/](#)

The VNC server was secured with the password [password](#). Connected using a VNC client — full graphical desktop control granted immediately.

4. Apache PHP-CGI Remote Code Execution — CVE-2012-1823 (CVSS 7.5)

Port: 80 | **PoC Folder:** [POC/Apache PHP-CGI Remote Code Execution/](#)

PHP-CGI allows command-line arguments to be passed via query strings. Validated with a crafted POST request — the server executed the [id](#) command confirming remote code execution.

5. Apache Tomcat Ghostcat — CVE-2020-1938 (CVSS 5.0)

Port: 8009 | **PoC Folder:** [POC/AJP connector POC/](#)

The AJP connector allows unauthenticated file reads from within the web application. Successfully read [WEB-INF/web.xml](#) — confirming the vulnerability. On upload-enabled servers this escalates to RCE.

6. SSL Version 2 and 3 Protocol Detection (CVSS 9.8)

Ports: 25, 5432 | **PoC Folder:** [POC/SSL POC/](#)

SSLv2 and SSLv3 are both active — exposing connections to POODLE and DROWN attacks via insecure padding and weak session renegotiation.

7. phpMyAdmin SQL Injection — CVE-2019-11768 (CVSS 5.0)

Port: 80 | **PoC Folder:** [POC/phpMyAdmin POC/](#)

Installed version (3.1.1) is vulnerable to SQL injection in the designer feature. An unauthenticated attacker can disclose or modify arbitrary database content.

● High Findings — Covered in Part 2 Article

8. TWiki 'rev' Parameter Command Execution — CVE-2005-2877 (CVSS 4.0)

Port: 80 | **PoC Folder:** `POC/TWiki Users POC/`

Shell command injection via the `(rev)` URL parameter. Confirmed `(uid=33(www-data))` execution on the server.

9. NFS Shares World-Readable (CVSS 4.0)

Port: 2049 | **PoC Folder:** `POC/NFS POC/`

The root filesystem (`(/ *)`) is exported with no access restrictions — allowing any network user to read sensitive files including `(/etc/shadow)` and SSH keys.

10. rlogin / rsh Services — CVE-1999-0651 (CVSS 7.5)

Ports: 513, 514 | **PoC Folders:** `POC/rlogin POC/` · `POC/rsh Service Detection POC/`

Legacy cleartext protocols that transmit credentials in the open. Authentication can be bypassed via `(.rhosts)` files combined with ARP spoofing.

11. Samba Badlock Vulnerability — CVE-2016-2118 (CVSS 4.3)

Port: 445 | **PoC Folder:** `POC/Samba POC/`

Flaw in SAM/LSAD protocols allows a MITM attacker to downgrade authentication and execute arbitrary Samba network calls.

● Additional High Findings — PoC Evidence in Repository

#	Vulnerability	CVE	Port	PoC Folder
12	SSL Medium Strength Cipher Suites (SWEET32)	CVE-2016-2183	25, 5432	<code>POC/Sweet 32 POC/</code>

#	Vulnerability	CVE	Port	PoC Folder
13	PHP PHP-CGI Query String Parameter Injection	CVE-2012-1823	80	POC/Apache POC/
14	phpMyAdmin Setup Script PHP Code Injection (PMASA-2009-4)	CVE-2009-1285	80	POC/phpmyadmin error.php BBcode POC/
15	ISC BIND Service Downgrade / Reflected DoS	CVE-2020-8616	53	POC/Bind Service POC/
16	Apache Tomcat SEoL (<= 5.5.x)	—	8180	POC/Linux POC/
17	Canonical Ubuntu Linux SEoL (8.04.x)	—	80	POC/Linux POC/

● Medium Findings — PoC Evidence in Repository

#	Vulnerability	CVE	Port	PoC Folder
18	Unencrypted Telnet Server	—	23	POC/Telnet POC/
19	HTTP TRACE / TRACK Methods Allowed	CVE-2003-1567	80	POC/HTTP trace and track POC/
20	SSL Certificate Cannot Be Trusted	—	25, 5432	POC/SSL Certificate POC/
21	SSL Self-Signed Certificate	—	25, 5432	POC/SSL Certificate POC/
22	SSL Certificate Expiry	—	25, 5432	POC/SSL Certificate POC/
23	SSL Certificate with Wrong Hostname	—	25, 5432	POC/SSL Certificate POC/
24	SSL Weak Cipher Suites Supported	—	25	POC/SSL Cipher POC/
25	SSL RC4 Cipher Suites Supported (Bar Mitzvah)	CVE-2013-2566	25, 5432	POC/SSL RC4 Cipher POC/
26	SSL Anonymous Cipher Suites Supported	CVE-2007-1858	25	POC/SSL Cipher POC/

#	Vulnerability	CVE	Port	PoC Folder
27	SSL DROWN Attack Vulnerability	CVE-2016-0800	25	POC/SSL Vesion POC/
28	SSL/TLS EXPORT_RSA <= 512-bit (FREAK)	CVE-2015-0204	25	POC/SSL TLS Export_RAS=512 (Freak)/
29	TLS Version 1.0 Protocol Detection	—	25, 5432	POC/TLS POC/
30	SMB Signing Not Required	—	445	POC/SMB Signing not required/
31	Web Application Vulnerable to Clickjacking	—	80, 8180	POC/Clickjacking POC/
32	Browsable Web Directories	—	80	POC/Browsable Web Directories/
33	phpMyAdmin file_path Parameter Vulnerabilities (PMASA-2009-1)	—	80	POC/phpMyAdmin POC/
34	phpMyAdmin setup.php Verbose Server Name XSS (PMASA-2010-7)	CVE-2010-3263	80	POC/phpmyadmin error.php BBcode POC/
35	phpMyAdmin error.php BBcode Tag XSS (PMASA-2010-9)	CVE-2010-4480	80	POC/phpmyadmin error.php BBcode POC/
36	PHP expose_php Information Disclosure	—	80	POC/PHP expose info POC/
37	Backup Files Disclosure	—	80	POC/Backfile Disclouser POC/

● Low Findings — PoC Evidence in Repository

#	Vulnerability	CVE	Port	PoC Folder
38	SSH Server CBC Mode Ciphers	CVE-	22	POC/SSH weak algorithms POC/

#	Vulnerability	CVE	Port	PoC Folder
	Enabled	2008-5161		
39	SSH Weak Algorithms Supported	—	22	POC/SSH weak algorithms POC/
40	SSH Weak MAC Algorithms Enabled	—	22	POC/SSH weak algorithms POC/
41	SSH Weak Key Exchange Algorithms Enabled	—	22	POC/SSH weak algorithms POC/
42	SSLv3 POODLE Vulnerability	CVE-2014-3566	25, 5432	POC/POODLE POC/
43	SSL/TLS EXPORT_DHE <= 512-bit (Logjam)	CVE-2015-4000	25	POC/SSL TLS Diffie-Hellman Modulus/
44	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	CVE-2015-4000	25	POC/SSL TLS Diffie-Hellman Modulus/
45	Web Server Transmits Cleartext Credentials	—	80, 8180	POC/Web Server Transmits Cleartext Credentials/
46	Web Server Allows Password Auto-Completion	—	8180	POC/Web Server Allows Password Auto-Completion/
47	X Server Detection	—	6000	POC/X Server Detection/
48	ICMP Timestamp Request Remote Date Disclosure	CVE-1999-0524	0	POC/ICMP Timestamp Request Remote Date Disclosure/
49	ISC BIND Denial of Service	CVE-2020-8617	53	POC/Bind Service POC/

⚠ Note on SMTP STARTTLS — False Positive

Nessus flagged SMTP STARTTLS Plaintext Command Injection on Port 25. This was independently validated using **Netcat** and **testssl** — both confirmed this vulnerability does **not exist** on the target. It was excluded from the PoC evidence as a false positive.

This is an important reminder: scanner output is a starting point, not a conclusion. Every finding needs manual validation before being reported.

Key Takeaways

These mirror the conclusions from the Part 2 article:

- **Nessus is a starting point, not a conclusion** — the real work is validating which findings have genuine exploitability
 - **Writing your own tools matters** — the custom bash script for CVE-2008-0166 forced a much deeper understanding than running a pre-built module would have
 - **Legacy services are dangerous** — rlogin, rsh, Telnet, SSLv2, SSLv3 consistently appear in real assessments and represent serious risk
-

This project was conducted in a controlled, isolated lab environment for educational and portfolio purposes only.